



2012

CNSS FY2012

ANNUAL REPORT



February 2013



Committee on National Security Systems

February 2013

The Defense, Intelligence, and Civilian communities must collectively develop and implement the capability to meet current and future threats—prevent their activity when possible and protect and defend National Security Systems (NSS). Through unified policy development and implementation, leadership for interagency efforts and engagement with stakeholders from across the larger information assurance community the Committee on National Security Systems (CNSS) provides leadership for the Nation. The CNSS Committee and Subcommittee provide coordination and promote mission bridging among departments and agencies that own and operate NSS and are responsible for safeguarding and sharing information within those systems.

The CNSS provides a unique and essential leadership and coordination role among Federal departments and agencies to meet the cyber challenges facing our Nation today and in the future. CNSS and the National Institute of Standards and Technology have successfully collaborated to synchronize efforts for safeguarding NSS and protecting non-NSS. This leadership has moved our Nation closer to achieving a common approach for increasing system and network security across the U.S. Government. The CNSS has built on this success to embrace a new governance structure that promotes interagency collaboration and coordination to develop policies to manage risks to NSS and the Secret Fabric (*i.e.*, all Secret networks irrespective of the owner of the network). We are operating with a greater sense of urgency—meeting more frequently, approving issuances quickly, establishing collaboration spaces, and focusing on collective risks to the enterprise.

We must continue the momentum of the past year, build on our individual and collective successes, and hold ourselves accountable to ensure the continued security of NSS.

Sincerely,

/s/

Teri Takai

Chair
Committee on National Security Systems

/s/

Richard Spires

Co-Chair
Committee on National Security Systems



INTRODUCTION

Federal department and agency networks and information across the Defense, Intelligence, and Civilian communities are constantly under attack and the threat landscape is routinely changing. For example, the Wiki Leaks incident and other data breaches highlight the insider threat as one of the greatest risks to government information systems. Similarly, nation-state and non-state adversaries operate in the same global information environment as U.S. organizations resulting in persistent challenges for our computer network defenses. Advanced persistent threats remain determined to disrupt or deny our ability to operate. Cyber conflict has progressed from a theoretical tool to a technically practical, common component of political, economic, and criminal activities.



Future struggles will likely include some level of cyber conflict, either by patriotic hackers, criminals, non-state or state-sponsored cyber warfare units. Adversarial actions in cyberspace are not confined geographically; they permeate the national and international fabric and have become a national problem requiring a whole-of-government solution. Governance structures, policies, and tactics, techniques, and procedures must evolve to mitigate and address the varied threats and vulnerabilities—advanced persistent threat, insider threat, zero-day exploits, removable media and data leakage, phishing attacks, flaws and weaknesses in web-based applications and software, and rapid technological changes—which put National Security Systems (NSS)¹ and National Security Information (NSI) at risk. The new normal requires enhanced cyber security vigilance and diligent action on the part of all Federal departments and agencies to implement capabilities, continuously monitor NSS, and manage risk to the entire enterprise.

The Committee on National Security Systems (CNSS) is the interagency body responsible for safeguarding NSS and in 2012, the Senior Information Sharing and Safeguarding Steering Committee (Steering Committee)² designated the CNSS as the lead for integrated management of the Secret Fabric.³ Through an exhaustive review, the Steering Committee identified functions relevant to the management of the Secret Fabric as an enterprise, sought a single coordination point through which to manage the Secret Fabric as an enterprise, and identified the CNSS as the appropriate body. The new CNSS governance structure enables the CNSS to address the full range of Secret Fabric activities and foster closer coordination of operations across the Secret Fabric.

Recognizing the urgency with which the Defense, Intelligence, and Civilian communities must come together to address the current and future threats, the CNSS has restructured itself to be a truly interagency policy, standards, and governance body consistent with the vision, goals, and objectives of Executive Order (E.O.) 13587 and the Steering Committee. While the Department of Defense (DoD) continues to Chair the CNSS, in order to emphasize interagency coordination, the CNSS Members approved by vote the addition of a Co-Chair position, rotating between the Civilian and Intelligence agencies. Department of Homeland Security (DHS) was approved to serve as the first CNSS Co-Chair. Members also approved a process for adding new Members and Observers to the CNSS Membership. Additionally, CNSS Working Groups (WG) have been aligned under four new functional Panels—Architecture, Safeguarding, Information Sharing, and Operations Policy. To ensure continued confidence in our Nation's classified information systems and networks, the Steering Committee, and consequently the CNSS, is focusing attention on ensuring departments and agencies make progress in five priority areas for the NSS—removable media, identity management, insider threat, access control, and enterprise audit.

To “move at mission speed” in the execution of its responsibilities, the CNSS adopted a significantly streamlined process for voting on issuances, which will promote timely decision-making and promulgation of issuances. A primary way CNSS addresses the evolving threat to NSS is by developing consistent policies and instructions for all NSS owners and operators. These documents, developed in collaboration with multiple Federal departments and agencies, provide national-level policy; address a wide variety of needs; and form a foundation for all Federal departments, agencies, bureaus, and offices with NSS. Additionally, CNSS is looking across all existing issuances to ensure their

1 NSS are any information system (including telecommunications systems) used or operated by an agency or by a contractor of any agency, or other organization on behalf of an agency, the function, operation, or use of which (i) involves intelligence activities; (ii) involves cryptologic activities related to national security; (iii) involves command and control of military forces; (iv) involves equipment that is an integral part of a weapon or weapon system; or (v) subject to subparagraph (B), is critical to the direct fulfillment of military or intelligence missions; or is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive Order or Act of Congress to be kept classified in the interest of national defense or foreign policy. Subparagraph (B) does not include a system that is to be used for routine administrative and business applications (*e.g.*, payroll, finance, logistics, and personnel management applications). (Title 44 U.S. Code Section 3542, Federal Information Security Management Act of 2002).

2 Executive Order (E.O.) 13587, *Structural Reforms to Improve the Security of Classified Networks and the Responsible Sharing and Safeguarding of Classified Information*, established the Steering Committee, which exercises overall responsibility and ensures senior-level accountability for the coordinated interagency development and implementation of policies and standards regarding the sharing and safeguarding of classified information. E.O. 13587 reaffirmed the authorities in National Security Directive 42, *National Policy for the Security of National Security Telecommunications and Information Systems*.

3 Secret Fabric is a label given to all Secret networks irrespective of the owner of the network.

CNSS Guiding Principles

- ▶ Develop timely, clear, precise and flexible policy to safeguard NSS
- ▶ Lead, take action, and anticipate emerging issues impacting the security of NSS
- ▶ Provide both an information assurance and mission perspective necessary to balance safeguarding with information sharing
- ▶ Commit the resources necessary to expand the capacity of the CNSS to implement change and drive action

relevancy, currency, and completeness. Through engagement with key stakeholders across the Federal Government, academia, industry, and international partners, CNSS is ensuring that policy considers a broad set of interests and expertise.

The CNSS continues to collaborate with the National Institute of Standards and Technology (NIST) to harmonize information security policies and guidance for NSS and non-NSS. Cooperation to date between CNSS and NIST has been excellent. NIST has worked to incorporate language into their issuances to satisfy CNSS requirements regarding the protection of NSS. In turn, the CNSS adopted several NIST Special

Publications (SP) for NSS, and CNSS and NIST continue to work together to eliminate and reduce differences among their respective documents. The CNSS is also working closely with the joint Executive Agent for Safeguarding Classified Information on Computer Networks (*i.e.*, DoD and the National Security Agency (NSA)), which is responsible for developing effective technical safeguarding policies and standards and publishing such issuances through the CNSS.

For the past several years, CNSS has largely focused its efforts on risk management, trusted information sharing, identity assurance, network resilience, and building an information assurance (IA) workforce. Although these issues remain important to safeguarding NSS and the NSI within them, CNSS priorities for the future continue to expand and evolve to address current and future risks. CNSS and its Member departments and agencies are committed to providing the governance structure necessary to (1) identify and deploy capabilities to safeguard NSS, (2) promote accountability across the community, (3) manage enterprise risk, (4) manage response to incidents and maintain cyber readiness, and (4) build an NSS architecture for the future. While much has been done, the CNSS, as an interagency body, must remain vigilant and act quickly to address complex challenges in policy and in coordinated risk decisions.





IDENTIFYING AND DEPLOYING CAPABILITIES TO SAFEGUARD NSS

To effectively safeguard NSS, Federal departments and agencies need to implement security controls, technical solutions, and capabilities. The CNSS developed several issuances describing recommended IA capabilities and controls to increase the security of NSS, including how Federal departments and agencies should implement host-based security capabilities, conduct network mapping of NSS, deploy network intrusion detection and intrusion prevention systems, maintain a 24X7-computer incident response capability for NSS, and improve secure configuration management processes.



CNSS VISION ► Identify requirements necessary to safeguard NSS and NSI and counter current and future threats.

These issuances leverage the Community Gold Standard, which provides comprehensive and measurable IA guidance for securing enterprises while also enabling mission. The Community Gold Standard, developed by NSA, describes best practices for a set of capabilities that helps an organization increase its overall security posture and is the foundation for National Manager guidance on how best to harden NSS.⁴

Insider threat remains a serious concern for Federal departments and agencies. The capability to detect and prevent the insider threat is essential to maintaining the integrity and availability of NSS and NSI. Development of advanced, integrated insider threat defensive tools is also integral to thwarting the advanced persistent threat as detection and prevention tools address aspects of the threat including sabotage, negligence, human error, and social engineering exploits. Establishing a comprehensive insider threat detection and prevention program is challenging; however, it is necessary to prevent future incidents. Recognizing the need for guidance to assist departments and agencies in mitigating the threat, the CNSS worked closely with the National Insider Threat Task Force to develop CNSS Directive (CNSSD) Number (No.) 504, *Protecting NSS from the Insider Threat*. Several Member departments and agencies are in the process of planning and establishing elements of an insider threat program. For example, the Department of Justice (DOJ) and the Drug Enforcement Agency are working to strengthen and establish a framework and formal agreements and processes to effectively collaborate and correlate insider threat-related data with personnel security, counterintelligence, Inspector General, and human resources functions across DOJ and its components. DOJ has deployed centralized audit event monitoring and alerting capabilities on 80 percent of its networks

and systems. These capabilities, which are operated by DOJ's Security Operations Center (SOC), form the foundation for an information technology (IT)-enabled insider threat monitoring solution as additional capabilities are added to systems and end-points.

Furthermore, the Wiki Leaks incident highlighted how insiders and other actors can use removable media (e.g., thumb drives, CDs/DVDs) as a means for obtaining information or launching an attack. Departments and agencies are pursuing formal policies to manage the use and monitoring of removable media on classified systems. For example, in April 2011, DOJ issued new policy as well as corresponding requirements establishing the criteria for the use and monitoring of removable media on classified systems. The policy closely aligns with Intelligence Community Standard Number 500-18, Removable Media Management (effective 16 February 2011) and CNSS Policy (CNSSP) No. 26, *National Policy on Reducing the Risk of Removable Media*, and includes provisions for both authorization and risk-based decisions regarding the use of removable media. In addition, the Department of State is deploying "thin client" computer units without removable media options and limiting the ability to download material from classified terminals. The State Department has also updated computer security policies to prohibit the downloading of classified information to removable media without formal written approval.

The CNSS has had long-standing concerns over the risks associated with incorporating globally-sourced components into the NSS of the future. The U.S. Government must address the reality that the global marketplace provides increased opportunities for adversaries to penetrate commercial supply chains to subvert the components bound for U.S. Government critical systems to gain unauthorized access to data,

4 National Security Agency Memorandum for All Departments and Agency Senior Officials Charged with Overseeing Classified Information Sharing and Safeguarding Efforts on Computer Networks, 2012 Minimum Baseline for National Security Systems, 31 January 2012. 2 Executive Order (E.O.) 13587, Structural Reforms to Improve the Security of Classified Networks and the Responsible Sharing and Safeguarding of Classified Information, established the Steering Committee, which exercises overall responsibility and ensures senior-level accountability for the coordinated interagency development and implementation of policies and standards regarding the sharing and safeguarding of classified information. E.O. 13587 reaffirmed the authorities in National Security Directive 42, National Policy for the Security of National Security Telecommunications and Information Systems.

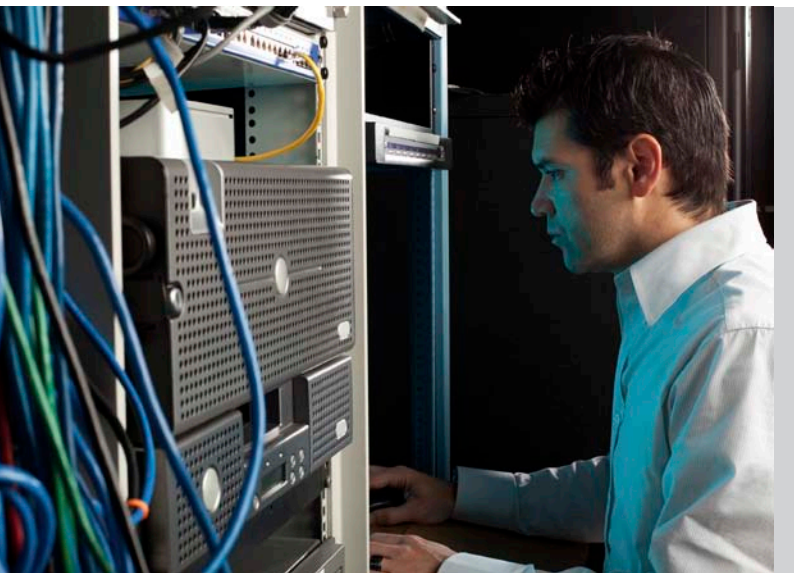
alter data, interrupt communications, or disrupt critical infrastructures. The CNSS developed and published CNSSD No. 505, *Supply Chain Risk Management*, aimed at managing such risks. Significant work is being undertaken in accordance with the directive including work at DOJ, DoD, DHS, and the Department of Energy.

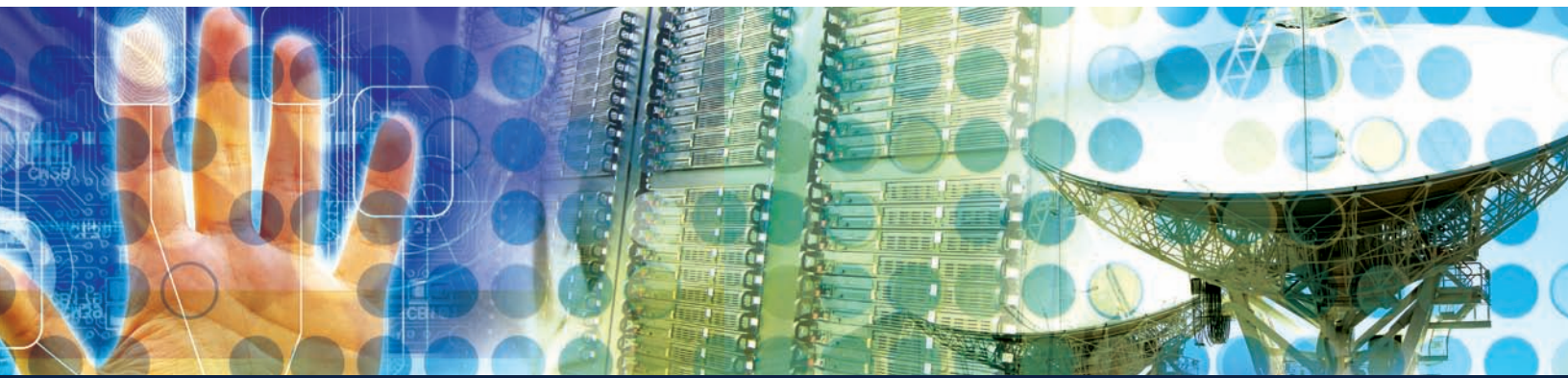
The responsibility of the CNSS to safeguard NSS extends to space systems, which are increasingly leveraged to satisfy national security requirements. In addition, space activities are closely linked to the operation of the critical infrastructures. Due to the importance of space activities, the greater interconnectivity of space systems with, and reliance on, space and other non-space systems (government, commercial, and foreign), and increasing threats to space systems, the CNSS revised CNSSP No. 12, *National Information Security Policy for Space Systems Used to Support National Security Missions*. The revised CNSSP No. 12 addresses the importance to NSS of transmission security and communications security as part of integrated systems engineering and information systems security engineering; the importance of employing good supply chain risk management practices; the need to secure all telemetry; the growing use of commercial space capabilities; and the requirement to provide information security for all applicable space systems.

The CNSS increased individual department and agency use of the NSS Public Key Infrastructure (PKI) Root and made significant progress toward the establishment of the NSS PKI Common Service Provider (CSP) to provide PKI support to NSS across the Federal Government.

Departments and agencies are committed to the use of PKI on the Secret Fabric. The Defense Information Systems Agency will serve as the NSS PKI CSP. The CNSS published CNSSD No. 506, *National Directive to Implement PKI for the Protection of National Security Systems on Secret Level Networks*, which mandates and guides the use of the NSS PKI for authentication to all Federal Secret networks. Implementation of the NSS PKI will significantly protect Federal Secret networks and satisfy many of the goals and requirements outlined in E.O. 13587, Comprehensive National Cybersecurity Initiative (CNCI) Number 7, and Office of Management and Budget Memorandum M-11-11, *Continued Implementation of Homeland Security Presidential Directive 12– Policy for a Common Identification Standard for Federal Employees and Contractors*. The NSS PKI will support user authentication, digital signature, nonrepudiation, and application authorization while preventing anonymity on classified computer networks. DoD began deployment of PKI hardware tokens on its Secret network with a goal of completing deployment by December 2012.

The NSS PKI certificate is a baseline identity management tool in the same way that the Federal PKI certificate is a baseline identity management tool on Personal Identity Verification/Common Access Card credentials. An individual's identity, along with their security clearance, citizenship, and need for an NSS PKI certificate, is rigorously established before the certificate is generated. That certificate is then cryptographically bound to that individual's identity. The NSS PKI certificate used for classified network access and authentication can be used to ensure that only specifically authorized individuals have access to the network and its data, and that it can be transmitted only to other individuals authorized to receive it. NSS PKI implementation and use across Federal departments and agencies will help manage identity and drive out anonymity. This effort provides departments and agencies with the capability to deter and prevent another Wiki Leaks-type event and enables secure information sharing among Federal partners. Additionally, the PKI technology streamlines business processes by providing a digital signature capability to sign electronic documents and avoids hardcopy paperwork. Furthermore, the NSS PKI enables access controls to be assigned and evaluated against the individual, which allows for the monitoring of access privileges on a more granular basis.





PROMOTING ACCOUNTABILITY ACROSS THE COMMUNITY

The CNSS identified an initial set of IA measures for networked NSS used for internal agency and/or interagency information sharing of classified information. A number of quick hit and near-term machine-readable measures for operating system (OS) patch management, anti-virus management, removable media management, and software management were identified for immediate implementation. Additional measures for OS patch management, asset management, bandwidth management, event management, incident management, vulnerability management, compliance management, cryptographic management, and authorization and assessment management were recommended for future implementation after requirements are defined and the capability to collect in an automated manner exists.



CNSS VISION ► Gain additional transparency into the security of NSS to understand areas of greatest risk and make informed decisions to buy-down risk.

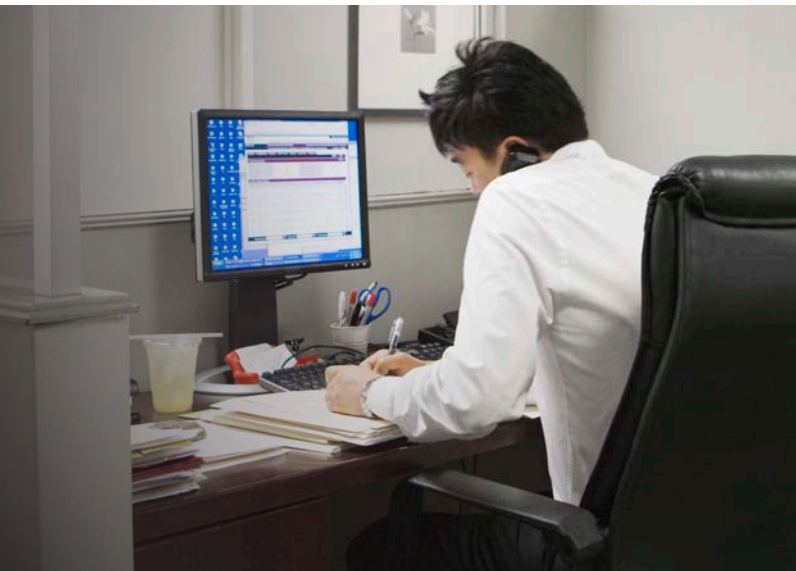
These measures need to be integrated into continuous monitoring for networked NSS and the capability to collect and report on many of the measures will need to be put in place.

An emphasis on the development and deployment of a holistic, robust, and integrated continuous monitoring capability is essential to containing and/or reducing the persistent threat. An effectively designed and managed continuous monitoring capability provides essential, near real-time security information. With this information, leaders are able to make better informed decisions regarding immediate risk mitigation actions along with cost-effective, mission enhancing risk-based decisions concerning information systems operations. CNSS departments and agencies are leading the way in implementing and piloting continuous monitoring approaches and defining individual thresholds. The Department of the Treasury continues to enhance its overall continuous monitoring capability through active membership in the Federal Chief Information Officer (CIO) Council's Information Security and Identity Management Committee (ISIMC) Continuous Monitoring WG, adoption of CNSS policies and community best

practices, and implementation of continuous monitoring at the system level. Treasury's Top Secret network has operated under a formal continuous monitoring process since December 2010. This has produced several incremental improvements to the overall security of the network and highlighted several new risks.

The State Department has continued to work on the deployment of a continuous monitoring tool to detect anomalies on their classified network that would not be readily apparent. This capability is supported by a professional staff, which will promptly analyze these anomalies to ensure that they do not represent threats to the system. In addition, DHS currently applies continuous monitoring to its NSS consistent with current guidance and concepts outlined by NIST. It is involved in the development of policy and guidance from the Intelligence Community (IC) and CNSS, to include expansion of SOC capabilities to meet CNCI-7 requirements. Finally, the CNSS is working to establish PKI-unique requirements and procedures for conducting continuous monitoring that do not violate or degrade the trust model requirements established by CNSS Instruction (CNSSI) No. 1300, *NSS PKI X.509 Certificate Policy*. NSS PKI Certification Authorities (CA) have unique security requirements for multi-person access controls, separation of duties, and connectivity requirements to create a trust model whereby certificates issued by one agency CA can be trusted by another agency as following identical requirements exactly.

The CNSS will continue to work closely with the Federal CIO Council and individual departments and agencies to synchronize activities related to continuous monitoring and compliance for NSS and non-NSS. Specific points of coordination include (1) assessing the security posture of departments and agencies, (2) collecting information from departments and agencies on their efforts to implement safeguards and comply with specific IA measures, and (3) ensuring personnel have the skills and expertise necessary to make informed security decisions and manage compliance with identified requirements.





MANAGING ENTERPRISE RISK

The management of information and networks transcends organizational boundaries. When an organization's networks are connected to external systems, the management responsibilities for that enterprise extend beyond the organization. CNSS success in securing NSS and making smart decisions regarding how to manage risk to the Secret Fabric as an enterprise depends on its ability to establish policies, procedures, standards, and architectures to gather, analyze, and share information not only for situational awareness but to facilitate the harmonization of technology, standards, policy, and privacy.



CNSS VISION ► Collectively manage risk across the entire NSS enterprise by embracing the interconnectedness of all fabrics and the impact that actions by one have on others.

The CNSS is working to develop a National Secret Enclave Policy for the Secret Fabric, which will define the minimum standards for connection to this highly interconnected community. Development of the national enclave policy will define the core set of actions that departments and agencies need to do to interconnect, establishing greater trust in the security of the network and mitigating the risk inherited by all when one department, agency, or partner has inherent weaknesses.

The CNSS, as part of its efforts to move with greater speed and provide transparency into decisions regarding the security of NSS, is also examining interagency processes for coordinating decisions regarding Secret Fabric network and information system interconnections. Specifically, the CNSS is developing a CNSS Enterprise Risk Management Board (CERMB) charged with providing oversight for risk management-related activities across the National Security System (NSS) fabric, deferring to the IC Information Security Risk Management Committee (ISRMC) for the TS/SCI fabric. The CERMB will make timely risk management recommendations to the CNSS regarding network and information system interconnections (including cross domain connections) and access to NSS, from any Federal Department to an organization outside of that Department, based on minimum connection standards, risk assessments, and operational impact.

The CNSS continued its longstanding partnership with NIST, DoD, and the Office of the Director of National Intelligence under the *Joint Task Force Transformation Initiative* to develop a common security framework for the Federal Government, including NSS, in order to provide the Intelligence, Defense, and Civil sectors and their contractors, more uniform and consistent ways to manage the risk to organizational operations and assets, individuals, other organizations, and the Nation that results from the operation and use of information systems. It also provides a strong basis for reciprocal acceptance of security authorization decisions and facilitates information sharing. The CNSS fully adopted the first four Joint Task Force publications (NIST SP 800-53, NIST SP 800-53A, NIST SP 800-37, and NIST SP

800-39) in its update of CNSSP No. 22, *Policy on Information Assurance Risk Management for National Security Systems*. The CNSS also updated CNSSI No. 1253, *Security Categorization and Control Selection for National Security Systems*. Finally, the CNSS supported the development of NIST SP 800-30, Revision 1, *Guide for Conducting Risk Assessments*, the fifth Joint Task Force publication which uses the key risk factors of threats, vulnerabilities, impact to missions and business operations, and the likelihood of threat exploitation of weaknesses in information systems and environments of operation, to help senior leaders and executives understand and assess the current information security risks to their organizations and IT infrastructures.

In addition, the CNSS worked closely with the DoD/IC Security Controls WG to draft a space overlay for security controls for inclusion in CNSSI No. 1253. Overlays are structured additions or subtractions of security controls to established baselines reflecting environmental or operational considerations, in this case, space operations and environment. The intent of the overlay is to provide a common starting point (*i.e.*, an adjusted security controls baseline) and to assist system designers, developers, assessors, and authorizing officials in minimizing the effort expended to select a system-specific security controls baseline for various space systems, while also providing a greater degree of reciprocity between and among interconnected space and non-space systems. The space overlay also provides supplemental guidance for nearly 600 security controls and enhancements (from NIST SP 800-53, *Recommended Security Controls for Federal Information Systems and Organizations*) to assist practitioners in selecting/de-selecting and correctly implementing the security controls appropriate for their specific circumstances. The supplemental guidance translates the intent of generic security controls designed for ground-based IT to often very unique space-specific implementations.

Departments and agencies are equally committed to managing enterprise risk. DHS established a NSS Risk Management Division within the Office of the DHS Chief Information Security Officer and an interdepartmental group, the DHS Information Safeguarding and Risk

Management Council to serve as the NSS Risk Executive Function. The NIST Risk Management Framework (RMF) and risk management at the organizational level are being integrated into these activities and codified within DHS NSS policies. The State Department continues its aggressive implementation of policies and standards to avoid, reduce, or mitigate risks to NSS. Security professionals work from both headquarters and their overseas stations at NSS sites to implement and maintain programmatic and physical countermeasures to protect NSS. The State Department is transitioning from the Four Phase RMF proscribed by Director of Central Intelligence Directive 6-3, *Protecting Sensitive Compartmented Information within Information Systems* to the Six Step RMF defined under Intelligence Community Directive 503, Intelligence Community Information Technology Systems Security Risk Management, Certification, and Accreditation (15 September 2008), which includes the

policies, standards, and procedures promulgated by CNSSP No. 22, *Policy on Information Assurance Risk Management for National Security Systems*.

Treasury adopted the RMF and conducts annual reviews and updates of internal policies governing NSS, which include a test of the effectiveness of this security control area. DOJ has a mature risk management program that contains a combination of continuous monitoring technologies and capabilities for near real-time network situational awareness, robust system and application authorization processes and testing/validation resources that provides visibility to make accurate risk decisions. The Program is housed in the Department's Office of the CIO and features a mature Departmental governance and policy structure. This structure allows the Department to swiftly align policy and programs to meet the new requirements resulting from E.O. 13587 and the CNSS.





MANAGING RESPONSE TO INCIDENTS AND MAINTAINING CYBER READINESS

Cybersecurity threats are not static; the scope, number, and complexity of cyber attacks are changing and expanding. Of primary concern is the threat of organized cyber attacks capable of causing debilitating disruption. Cyber attacks on U.S. information networks have serious consequences—from disrupting critical operations, causing loss of revenue and intellectual property, to even loss of life. Rapid identification, information exchange, and remediation often can mitigate the damage resulting from malicious cyberspace activity. In March 2011, the CNSS responded to a cyber attack targeting RSA's SecurID two-factor authentication solution.



CNSS VISION ► Ensure U.S. economic competitiveness and national power by deploying a technologically advanced workforce to effectively deter and respond to growing threats in cyberspace.

The CNSS coordinated a formal data call of the Membership to collect information on the scope and impact of the incident on NSS. The CNSS was able to help facilitate the delivery of replacement tokens to Federal departments and agencies. Additionally, the collected data allowed NSA to assist RSA in prioritizing the distribution of replacement tokens.

CNSS departments and agencies maintain programs to manage incident response. For example, DHS maintains the National Cybersecurity and Communications Integration Center, a 24x7 center responsible for the production of a common operating picture for cyber and communications across the Federal, state, and local government; intelligence and law enforcement communities; and the private sector. DOJ operates a 24x7 SOC that monitors its classified enclaves. The SOC maintains a full-time cyber threat analysis capability that interfaces with the IC, DoD, other Federal departments and agencies, and commercial partners to track and analyze advanced cyber threats. This capability fuses classified and open source information to create a customized and comprehensive threat picture for DOJ and its components. State's 24x7 Cyber Incident Response Team (CIRT) conducts security monitoring of its classified networks to ensure the integrity, availability, and confidentiality of its IT infrastructure. The CIRT provides near real-time detection, collection, analysis, correlation, and reporting of cybersecurity events that pose a threat to State's networks.

Several CNSS departments and agencies also conducted tests to uncover strengths and weaknesses and participated in cyber exercises to improve their cyber incident response capabilities. DOJ established a Vulnerability Assessment and Penetration Test (VAPT) Team to review its systems. The VAPT Team conducts assessments of various computing assets, including web applications, network infrastructures, databases, general support systems, and wireless networks, among others. Additionally, DOJ annually conducts a continuity of operation exercise for all of its computer systems. To meet Federal Information Security Management Act

requirements, users of the State Department's TS/SCI NSS completed an annual Disaster Recovery Contingency Plan Tabletop exercise. During this exercise, key members of the State Department's Disaster Recovery team gathered to work through a simulated incident. Additionally, Treasury regularly sponsors department-specific cyber exercises and participates in national-level cyber exercises (e.g., Eagle Horizon).

To combat current and future cyber threats and ensure continued readiness, departments and agencies must be able to recruit and retain top talent in cybersecurity and IA. The Federal Government also must develop uniform technical certification standards for cybersecurity specialists and provide opportunities for staff to enhance their skills. The CNSS is responsible for developing baseline standards for IA education, training, and awareness for the National Security Community and works closely with the National Initiative for Cybersecurity Education (NICE), which seeks to establish an operational, sustainable, and continually improving cybersecurity education program for the nation. CNSS representatives participate in NICE activities to ensure NSS equities are represented and non-NSS and NSS efforts are synchronized.

Additionally, CNSS Members and Observers took other independent actions in 2011 to ensure their departments and agencies maintained or enhanced their cyber skills. DOJ required its employees to complete annual Computer Security Awareness Training and hosted an annual IT professional training series, CyberFest. The State Department required computer users to complete and pass an annual online Cyber Security Awareness course and began offering a new video briefing to remind users what is and is not permitted when working on classified networks. Treasury continued to maintain a strong Cybersecurity Awareness Program and achieved a 100 percent completion rate for its annual NSS awareness and specialization training. 99.5 percent of DoD's personnel completed IA awareness training and 80 percent of its IA workforce holds professional IA certificates.



BUILDING AN NSS ARCHITECTURE FOR THE FUTURE

The set of systems and networks that comprise the NSS architecture for the Federal departments and agencies is complex, bringing together a multitude of legacy environments. To understand the security posture of the Government's NSS, the CNSS must first understand and have transparency into the current topology of the Secret Fabric. The CNSS is working to define the baseline architecture and from there will develop a common high-level architectural framework to achieve interoperability of interconnected Secret-level networks. Steps will be identified to move from the "as is" state to a "to be" optimization effort, which will contribute to building an NSS architecture that includes minimum standards and requirements necessary to make interconnections in a trusted and safe environment.

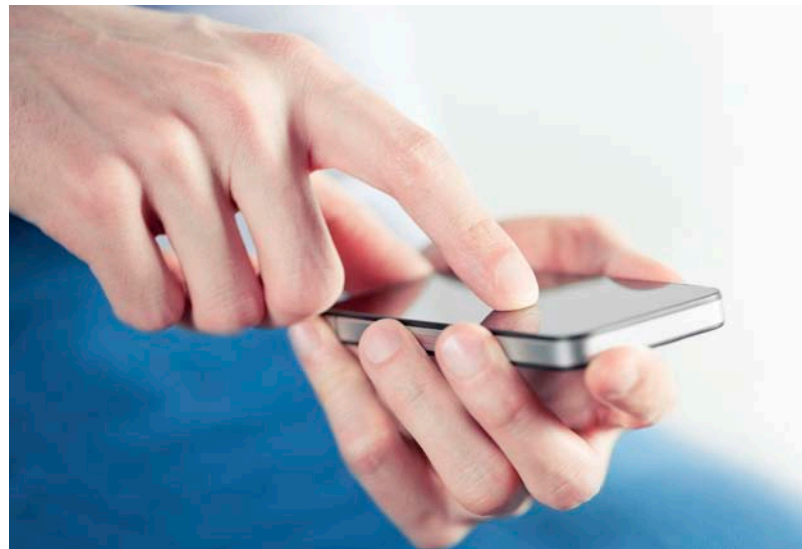


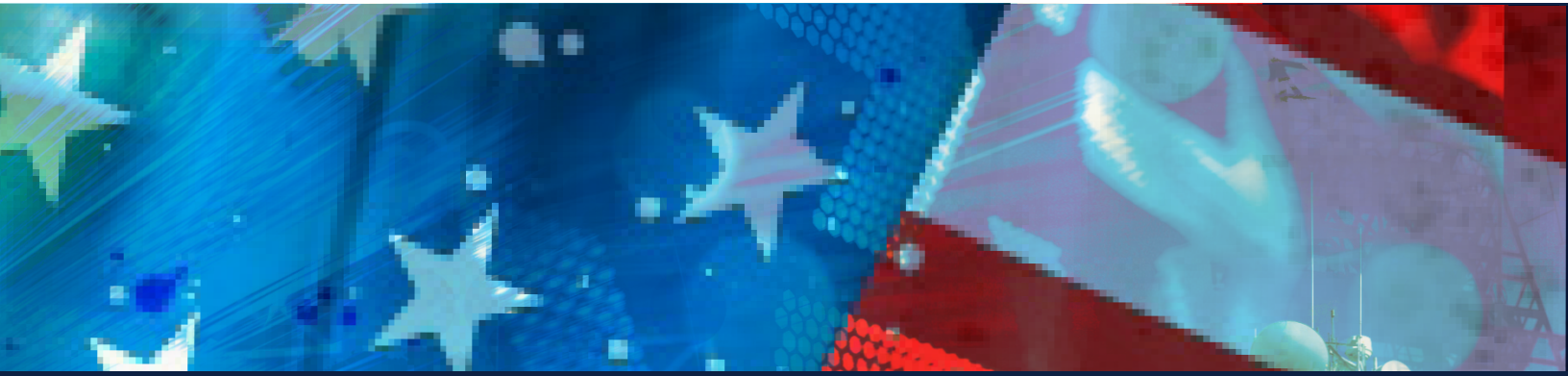
CNSS VISION ► Continue to reap the benefits of new technologies while managing the risks to NSS and NSI through greater transparency and accountability.

Building an NSS architecture for the future must also take into account technological advancements and support the movement of services and capabilities to new technologies that enhance missions and promote efficiencies such as cloud computing and wireless technologies. However, as departments and agencies increase their reliance on these new technologies and move to accomplishing national security missions through these technologies, it is essential to anticipate security needs. For example, elements critical to security (e.g., an agile key management system that supports confidentiality and identity management requirements; automated and dynamic policy management; user, administrator, and non-person entity accountability; data tagging, access control, and tracking; availability of enterprise services and data; continuous visibility into the operational and security status of cloud components and workloads; and timely and adaptable business processes for cloud management and security, including provisioning, resource allocation, accreditation, incident response, and decommissioning) cannot be satisfied with minor adaptations of current mechanisms and processes. For the foreseeable future, existing networks and emerging cloud implementations will co-exist in a hybrid environment. Secure operations and effective IA for community-scale clouds will require scalable enterprise services, ubiquitous automation, and cultural change for data owner, end user, and accreditation constituencies.

Users are increasingly demanding anytime, anywhere access to data, services, and other users to successfully and securely achieve their mission. Mobile and wireless devices should enable the workforce to enhance mission effectiveness while fostering creativity and allowing for information sharing. Departments and agencies must employ new defensive operating concepts, partner with the private sector, and leverage the younger generation's talent and innovation if the NSS community is going to effectively secure mobile technology. While wireless technology is largely not permitted in classified environments, with the exception of approved Secure Mobile Environment Portable Electronic Device products, departments and agencies are working to

detect unauthorized wireless devices within secured areas and working on the unclassified side to pilot the use of more secure mobile devices. For example, Treasury has continued to review and update its policies and procedures in the rapidly changing area of wireless technology and has implemented an active surveillance program to ensure adherence to these standards. The State Department is participating in an NSA pilot which uses Apple iOS and Google Android devices, and included in the pilot is a Federal Information Processing Standards 140-2, *Security Requirements for Cryptographic Modules*—certified mobile device management solution to help secure communications to these devices.





LOOKING FORWARD

The challenges facing NSS will continue to increase in scope and complexity as new technologies emerge and are adopted to fulfill mission requirements. Nation-state and non-state adversaries operate in the same global environment as we do, resulting in significantly increased challenges for our computer network defenses. They remain determined to disrupt or deny our ability to operate within cyberspace and are sufficiently advanced that they may be able to persist in our networks despite our best efforts to detect and dislodge them.

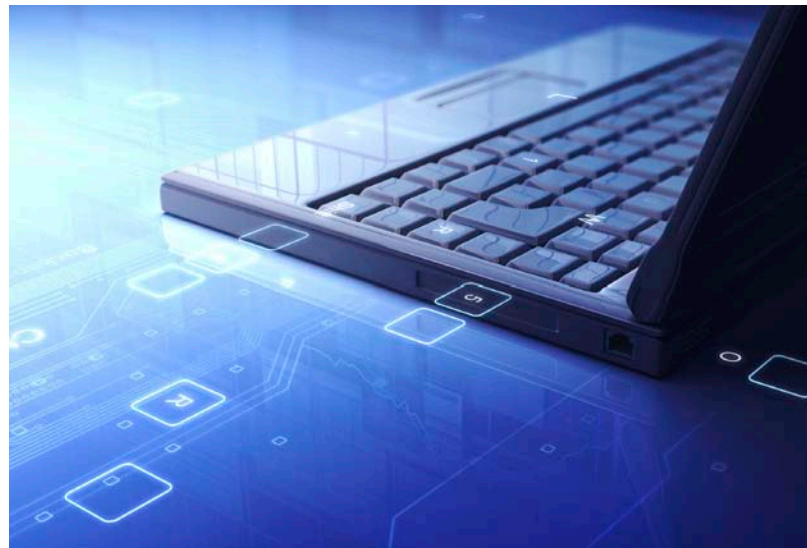


To safeguard NSS, departments and agencies need to have access to cutting-edge technologies (including automated cyber security tools and hardware) and associated professional services necessary to implement CNSS policies and recommended capabilities and security requirements. CNSS policies must be consistent and be developed to strengthen not inhibit department and agency missions. Requirements for Secret Fabric governance, particularly enterprise risk management and security operations, are rapidly evolving and represent a fundamental shift, which is going to take a significant amount of time and resources to implement. Future efforts to measure compliance with CNSS issuances should be linked to budget requests and take into account the resource constraints (e.g., technical personnel and funding), which require departments and agencies to balance security with efficiency gains.

Cyberspace dominance requires unity of purpose; synchronization, standardization, and enforcement of policies and directives; and an interoperable, integrated, dynamic governance structure. The CNSS Membership is unified in its commitment to move quickly and lead the Federal Government in safeguarding NSS.

Conclusion

As our use of technology to fulfill mission requirements continues to grow and the threats we face continue to evolve, safeguarding NSS and NSI remains one of the most crucial elements of our security posture. The accomplishments highlighted in this report demonstrate the vital role of the CNSS and its Membership in increasing the security of NSS in today's increasingly complex and dynamic environment. The CNSS provides a unique and essential leadership and coordination role among Federal departments and agencies to meet the cyber challenges facing our Nation today and in the future. The CNSS promotes interagency coordination and collaboration to develop policies and guidance that will move our Nation toward achieving a common approach for increasing system and network security across the U.S. Government for NSS. We must maintain the momentum and continue to work in partnership so that we can leverage existing expertise in meeting current and future cyber security challenges in a unified manner.





**CNSS Secretariat
National Security Agency**

9800 Savage Road, STE 6716
Fort George G. Meade, MD 20755-6716

410.854.6805 unclassified phone
410.854.6814 unclassified fax
410.854.0217 secure fax

cnss@radium.ncsc.mil
<http://www.cnss.gov>